

Autonomous Compliance Sentinel

Responsible AI Policy Catalogue, RAI-01 through RAI-09

SRH Heidelberg, Data Ethics and Responsible AI module. Author: Vikrant Singh and Kay Marc Muller. This catalogue is the retrieval corpus for the Goal 4 compliance agent. Each policy below is written in the same fixed order every time, Policy ID and name, Severity, Regulatory Basis, Requirement, Violation Patterns, and a Compliant Example, so that the meaning of any retrieved chunk stays clear even without the rest of the document around it. Severity is a fixed lookup value, not something the agent's language model decides at run time. Policies RAI-01 through RAI-05 are High severity and route to the human approval gate. Policies RAI-06 through RAI-09 are Medium severity and may proceed automatically with an optional spot check.

RAI-01: Data Protection

Severity: High

Regulatory Basis

This policy is grounded in Article 10 of the EU AI Act, which sets out data governance obligations for training, validation, and testing data used in high risk AI systems, and in Article 6 of the GDPR and the equivalent DSGVO provisions, which require every instance of personal data processing to rest on a clearly identified lawful basis such as consent, contract, or legal obligation. In the IBM AI Trust framework this policy corresponds to the Privacy pillar.

Requirement

Any project proposal that collects, stores, processes, or transfers personal, financial, health, or otherwise legally protected data must explicitly name the legal basis or regulatory framework under which that data is handled. This includes stating which law or internal policy governs the data category involved, and confirming that any cross border transfer, retention period, or third party sharing arrangement has been considered. A proposal that is silent on these points cannot be assessed as compliant, since the absence of a stated legal basis is itself the compliance gap this policy exists to catch.

Violation Patterns

A proposal processes financial, health, or legal case data without naming the law or internal policy it operates under. A proposal explicitly states that a relevant legal or regulatory requirement is not being met, which is the clearest possible signal of a violation. One real example drawn directly from this project's dataset is a disputes application requirement stating that it does not conform to the specific regulations governing credit card dispute processing under Regulation E and Regulation Z.

Compliant Example

A proposal for a customer support tool that processes billing records states that all data handling follows the company's GDPR Article 6(1)(b) contractual necessity basis, that records are retained for the statutory period required for financial disputes, and that no data leaves the EU processing region.

RAI-02: Transparency

Severity: High

Regulatory Basis

This policy is grounded in Article 50(1) of the EU AI Act, which requires that natural persons be informed when they are interacting with an AI system unless this is already obvious from context, and in Article 13 of the GDPR, which requires that data subjects be given meaningful information about the logic involved in any automated decision that affects them. In the IBM AI Trust framework this policy corresponds to the Transparency pillar.

Requirement

Any proposal in which an AI system interacts directly with a person, or makes or materially assists a decision about a person, must describe how that person will be informed of the AI system's involvement. This applies regardless of whether the interaction is a chatbot conversation, an automated email, or a decision such as an approval or rejection. The disclosure must be part of the system's design, not something left for a later stage of the project.

Violation Patterns

A proposal describes a chatbot, virtual assistant, or automated messaging system with no mention of disclosing to the user that they are talking to an AI system. A proposal describes an automated decision, such as an approval, denial, or score, being delivered to a customer with no statement of how or whether the customer is told an algorithm was involved.

Compliant Example

A proposal for a support chatbot states that every conversation opens with a clear statement that the user is speaking with an automated assistant, and that a human agent is one request away at any point in the conversation.

RAI-03: Fairness

Severity: High

Regulatory Basis

This policy is grounded in Article 10(2)(f) of the EU AI Act, which requires that training, validation, and testing data sets be examined for possible biases likely to affect the health, safety, or fundamental rights of individuals, or to lead to discrimination prohibited under EU law. In the IBM AI Trust framework this policy corresponds to the Fairness pillar.

Requirement

Any proposal that trains or applies a model using data that could carry demographic skew, such as historical hiring records, loan approvals, or user behaviour logs, must describe how the risk of biased or discriminatory outcomes across protected groups has been or will be evaluated. This does not require a finished fairness audit at the proposal stage, but it does require a concrete plan naming which groups will be checked and what metric will be used.

Violation Patterns

A proposal trains a model on historically imbalanced data, for example past hiring decisions or loan approvals, without mentioning any evaluation of outcomes across groups such as gender, age, or ethnicity. A proposal reuses an existing dataset known to reflect uneven historical treatment of a group without acknowledging that risk at all.

Compliant Example

A proposal for an automated resume screening tool states that shortlisting rates will be measured separately by gender and age band before launch, with a defined gap threshold that would trigger a manual review of the model.

RAI-04: Human Dignity and Vulnerable Groups

Severity: High

Regulatory Basis

This policy is grounded in Article 5(1)(b) of the EU AI Act, which prohibits AI systems that exploit the vulnerabilities of a person or a specific group due to age, disability, or social or economic situation in a way that materially distorts their behaviour and causes or is likely to cause harm. It extends the IBM AI Trust pillars of Fairness and Robustness into the specific domain of fundamental rights protection for people who cannot easily protect themselves.

Requirement

Any proposal whose data or user base includes people who may be vulnerable because of age, disability, illness, financial hardship, or a similarly precarious situation must describe the specific safeguards put in place for them. General fairness language addressed to the whole user base is not sufficient on its own when a vulnerable subgroup is present, since that subgroup can be harmed by a system that performs acceptably on average.

Violation Patterns

A proposal processes data from or makes decisions about a vulnerable population, such as elderly patients, people with disabilities, or financially distressed customers, with no mention of any special safeguard for them. This exact pattern appears almost verbatim in one of this project's own real proposals, which states plainly that vulnerable groups are processed without special safeguards.

Compliant Example

A proposal for an elder care monitoring system states that alerts involving a resident's medication or mobility are always routed to a human caregiver before any automated action is taken, and that family members can opt the resident out of any non essential monitoring feature.

RAI-05: Prohibited Purpose

Severity: High

Regulatory Basis

This policy is grounded in Article 5(1) of the EU AI Act as a whole, which lists AI practices considered to carry unacceptable risk and bans them outright regardless of accuracy, intent, or business justification. The clearest example within this list is Article 5(1)(c), which prohibits social scoring systems that evaluate people over time based on social behaviour or inferred personal characteristics and then apply the resulting score in unrelated contexts. This policy is not mapped to an IBM Trust pillar, since it functions as a hard prohibition rather than a quality dimension to be improved.

Requirement

Any proposal must be checked against the full list of practices Article 5(1) prohibits, which includes subliminal or manipulative behavioural techniques, exploitation of vulnerable groups, social scoring, individual predictive policing based solely on profiling, untargeted scraping of facial images, emotion recognition in the workplace or in education, biometric categorisation using sensitive attributes, and real time remote biometric identification in public spaces by law enforcement outside narrow exceptions. If a proposal's core functionality resembles any of these practices, no amount of additional safeguards makes it compliant, since the practice itself is banned.

Violation Patterns

A proposal assigns customers a persistent trust or reputation score derived from behaviour across unrelated services and then uses that score to gate unrelated future offers or access, which functions as a form of social scoring. A proposal infers emotional state from employees during work hours for performance management purposes, which falls under the workplace emotion recognition prohibition.

Compliant Example

A proposal for a fraud detection system scores individual transactions in real time based on that transaction's own risk signals, does not build a persistent behavioural profile of the customer across unrelated services, and does not use the score outside the fraud context it was built for.

RAI-06: Security

Severity: Medium

Regulatory Basis

This policy is grounded in Article 15 of the EU AI Act, which requires that high risk AI systems achieve an appropriate level of accuracy, robustness, and cybersecurity throughout their lifecycle, including resilience against attempts to exploit system vulnerabilities. In the IBM AI Trust framework this policy corresponds to the Robustness pillar.

Requirement

Any proposal must describe how the system protects the integrity of its data and its outputs against both accidental faults and deliberate interference. This includes basic input validation, protection against corrupted or malformed data, and a statement of what happens when the system receives input it was not designed to handle.

Violation Patterns

A proposal is entirely silent on how the system behaves when it receives invalid, malformed, or malicious input. This project's own dataset contains a real requirement marked as explicitly not met that illustrates the exact gap this policy targets, stating that the website shall prevent its data from being corrupted when incorrect data is entered in.

Compliant Example

A proposal for a data ingestion pipeline states that all incoming records are validated against a defined schema before being written to the database, and that malformed records are quarantined and flagged for review rather than silently accepted.

RAI-07: Human Oversight

Severity: Medium

Regulatory Basis

This policy is grounded in Article 14 of the EU AI Act, which requires that high risk AI systems be designed so that a natural person can effectively oversee their operation, including the ability to understand the system's output, decide not to use it, and intervene or halt the system when necessary. This is the same article that underpins the decision in this project's Goal 2 work to expose the logistic regression model's exact trigger words directly to human reviewers rather than only a probability score.

Requirement

Any proposal in which an automated decision is applied to a customer account, record, or similar outcome must describe the point at which a human can review or override that decision before it takes effect. A system that only allows a human to review decisions after they have already been applied does not satisfy this policy, since the oversight has to be capable of preventing the outcome, not just auditing it afterward.

Violation Patterns

A proposal applies a model's output, such as an approval, denial, or score, directly to a customer account or record with no reviewer step described anywhere in the proposal. A proposal mentions a review process only for exceptional or flagged cases, leaving the majority of decisions fully automated with no described oversight point at all.

Compliant Example

A proposal for an automated loan pre-approval tool states that the model produces a recommendation only, and that a loan officer must confirm every approval before funds are released, with the model's top contributing factors shown to that officer.

RAI-08: Data Minimisation

Severity: Medium

Regulatory Basis

This policy is grounded in Article 5(1)(c) of the GDPR and the equivalent DSGVO provision, which require that personal data collected be adequate, relevant, and limited to what is necessary for the stated purpose, reinforced by the EU AI Act's broader data governance expectations under Article 10 that data sets be relevant to the system's intended purpose. In the IBM AI Trust framework this policy also corresponds to the Privacy pillar, distinct from RAI-01 in that RAI-01 concerns the legal basis for holding data while RAI-08 concerns how much of it is held.

Requirement

Any proposal must describe what data is collected and retained, and that description must be limited to what the stated purpose actually requires. A proposal that collects or retains data beyond what its own stated purpose justifies violates this policy even if the extra data was never misused, since the risk this policy addresses is the existence of unnecessary data itself, not only its misuse.

Violation Patterns

A proposal stores full conversation transcripts indefinitely, including content unrelated to the support issue that prompted the interaction. A proposal collects optional demographic fields, such as income or family status, for a feature that does not require them, with no stated retention limit or justification.

Compliant Example

A proposal for a customer support chatbot states that only the specific fields needed to resolve a ticket are logged, that unrelated parts of the conversation are discarded, and that logs are deleted automatically after ninety days.

RAI-09: Explainability

Severity: Medium

Regulatory Basis

This policy is grounded in Article 12 of the EU AI Act, which requires that high risk AI systems automatically log events throughout their operation in a way that enables traceability of the system's functioning, appropriate to the system's intended purpose. This is the same article that underpins this project's Goal 2 decision to choose the logistic regression model's exact, reproducible coefficients over an approximate SHAP explanation for the comparison XGBoost model. In the IBM AI Trust framework this policy corresponds to the Explainability pillar.

Requirement

Any proposal must describe how an individual automated decision can be reconstructed and explained after the fact. This means the system must keep a record tying each decision to the specific inputs and model version that produced it, not only an aggregate accuracy figure for the system as a whole.

Violation Patterns

A proposal describes a model's overall accuracy or performance but gives reviewers no way to see which factors drove any single specific decision. A proposal has no logging mechanism at all for individual decisions, meaning a disputed decision from last month could not be reconstructed or reviewed.

Compliant Example

A proposal for an automated content moderation tool states that every removal decision is logged with the specific text flagged, the model version used, and the top contributing terms, so that any individual removal can be reviewed and explained on request.